

Skunkworks Academy

CESE323 ERC1.0 - Cloud Security
Envisioning & Strategy
Expanded Student Course Manual

Extensive technical learning content, implementation guidance, lab workflows, and learner worksheets

Manual purpose

This expanded manual gives learners deeper technical context for every module. It explains how the relevant Microsoft cloud security capabilities work, where they fit in the architecture, how to implement them safely, and what evidence to capture during labs.

Field	Value
Course code	CESE323 ERC1.0
Course name	Cloud Security Envisioning & Strategy
Audience	Security leaders, cloud administrators, security engineers, solution architects, and technical decision makers
Primary platform	Microsoft Azure, Microsoft Defender for Cloud, Microsoft Defender XDR, Microsoft Entra, Microsoft Sentinel, and Microsoft Purview
Document version	Expanded student manual draft
Date	25 May 2026

Document Control

Version	Date	Author/Owner	Change summary
ERC1.0 Expanded	25 May 2026	Skunkworks Academy	Expanded module education content with technical explanations, implementation steps, commands, pitfalls, evidence requirements, and scenario activities.

Training safety note

This manual includes implementation examples. Do not run commands or enable paid Defender plans in production or customer subscriptions unless scope, permissions, cost approval, and rollback plans are confirmed by the instructor and environment owner.

Table of Contents

1. 1. Course Overview
2. 2. Student Readiness and Lab Safety
3. 3. Course Module Structure
4. 4. Learning Architecture and Evidence Model
5. 5. Expanded Module Guides
6. 6. Worksheets and Templates
7. 7. Glossary
8. 8. Reference and Source Alignment
9. 9. Course Completion Checklist

1. Course Overview

CESE323 ERC1.0 - Cloud Security Envisioning & Strategy is a practical cloud security course focused on turning Microsoft cloud security capabilities into an actionable security strategy. The course moves from business risk and governance into Microsoft security architecture, posture management, workload protection, hands-on scenarios, and a final 30-day remediation roadmap.

1.1 Core Learning Outcomes

- Define cloud security goals and align them to organizational risk, compliance, data protection, and operational readiness.
- Explain how Microsoft Entra, Defender for Cloud, Defender XDR, Sentinel, Purview, Azure Policy, and workload protections fit into a unified architecture.
- Use CSPM capabilities to identify misconfigurations, vulnerabilities, regulatory control gaps, and attack paths.
- Evaluate Defender workload protection options for Storage, Containers, App Service, and AI Services.
- Apply scenario-based analysis to produce remediation tasks, owners, validation steps, and a 30-day roadmap.

1.2 Delivery Model

Mode	Description	Recommended use
Instructor-led workshop	Focused live delivery with selected workload modules and scenario review.	Customer workshops, executive technical sessions, facilitated adoption planning.
Self-paced course	All modules available with detailed reading, labs, worksheets, and capstone tasks.	Learner reinforcement, GitHub/LMS delivery, post-workshop completion.
Blended delivery	Live strategy and posture sessions followed by self-paced workload and capstone completion.	Enterprise cohorts and partner-led training.

2. Student Readiness and Lab Safety

Students must have working access, correct permissions, and a safe lab scope before any configuration activity begins. The course can be delivered as a live environment review, but live changes require explicit approval, named scope, and rollback planning.

2.1 Required Access

Access requirement	Why it matters
Microsoft Learn account	Used for module reinforcement, assessments, and source content alignment.
Azure portal access	Required for subscriptions, resources, Defender for Cloud, policy, and Cloud Shell.
Microsoft Defender portal access	Required for unified security operations, cloud alerts, incidents, and advanced hunting where used.
Microsoft Entra tenant access	Required for identity review, roles, MFA, Conditional Access concepts, and workload identity discussions.
Individual named account	Supports auditability and prevents changes being attributed to shared users.
MFA configured	Supports secure access and mirrors real operational requirements.

2.2 Permissions Model

Role	Typical use in this course	Caution
Reader	View posture, recommendations, inventory, compliance, and many resource properties.	Cannot perform most remediation or plan activation.
Contributor	Create lab resources and apply many configuration changes.	Does not grant access management rights by itself.
Security Admin	Manage Defender for Cloud security policy and security configuration tasks.	Should be scoped and approved.
Owner	Required for full control and some plan enablement scenarios.	Avoid broad assignment to all learners. Use only where justified.

2.3 Lab Safety Rules

- Use only approved subscriptions, resource groups, resources, and datasets.
- Do not upload production data, personal information, regulated records, secrets, keys, credentials, or customer-confidential files.
- Do not enable paid Defender plans unless cost approval and scope are confirmed.
- Do not modify production workloads unless the instructor and customer owner explicitly approve the change.
- Capture evidence carefully and redact sensitive values before sharing screenshots or reports.
- Clean up lab resources and disable test-only settings when instructed.

3. Course Module Structure

The learner-facing course contains 12 modules, numbered 00 to 11. Modules 06-09 are workload protection modules. For live delivery, the instructor may select two workload modules for deeper practical implementation while keeping all four in the self-paced manual.

Module	Title	Purpose	Output	Classification
00	Course Orientation	Introduce the course structure, audience, tools, and expectations.	Learner understands how to navigate the course.	Orientation
01	Cloud Security Strategy & Governance	Align security goals to business risk and compliance requirements.	Security goals worksheet.	Core
02	Microsoft Cloud Security Architecture	Explain Microsoft's unified security ecosystem.	Microsoft security stack map.	Core
03	Cloud Security Posture Management	Introduce CSPM, secure score, recommendations, compliance, and attack paths.	Posture review checklist.	Core
04	Defender for Cloud Configuration Control	Cover Defender plans, policies, onboarding, and governance controls.	Configuration readiness checklist.	Core
05	Workload Protection Decision Matrix	Help learners select priority workload protection areas.	Workload protection matrix.	Core
06	Defender for Storage	Explore storage protection, malware upload risks, and suspicious access.	Storage protection scenario review.	Workload Protection
07	Defender for Containers	Explore AKS, Kubernetes, image risk, and runtime protection.	Container security scenario review.	Workload Protection
08	Defender for App Service	Explore web app and cloud-native application protection.	App Service protection scenario review.	Workload Protection
09	Defender for AI Services	Explore GenAI security,	AI security risk review.	Workload Protection

Module	Title	Purpose	Output	Classification
		prompt injection, data leakage, and AI monitoring.		
10	Hands-On Security Scenarios	Apply course concepts to realistic security incidents.	Remediation planning worksheet.	Applied Practice
11	Capstone Roadmap	Build a practical 30-day security improvement plan.	Final remediation roadmap.	Capstone

4. Learning Architecture and Evidence Model

Every module follows a consistent learning pattern: understand the concept, inspect the environment, make or plan safe changes, validate the result, and capture evidence. This makes the course suitable for both technical learners and decision makers.

Learning phase	Student action	Evidence produced
Understand	Read the technical explanation and identify the control objective.	Notes, key terms, assumptions.
Inspect	Review portal data, resources, recommendations, alerts, roles, or configuration state.	Screenshots, exported findings, query results.
Implement or plan	Apply approved configuration or design the implementation sequence.	Configuration notes, change plan, commands.
Validate	Confirm the expected control state or document blockers.	Before/after state, alert state, recommendation state.
Remediate	Convert findings into actions with owners and dates.	Worksheet entries, roadmap tasks, capstone plan.

5. Expanded Module Guides

This section expands every module with technical details, implementation guidance, example commands, common pitfalls, and evidence expectations.

Module 00: Course Orientation

Attribute	Details
Classification	Orientation
Estimated learning time	30-45 minutes
Purpose	Introduce the course structure, audience, tools, and expectations.
Primary output	Learner understands how to navigate the course.
Recommended evidence	Signed readiness confirmation; Confirmed portal access list; Selected workload module track; Lab conduct acknowledgement

Learning outcomes

- Explain the CESE323 learning path, assessment evidence, and capstone deliverable.
- Identify the Microsoft portals, lab assets, worksheets, and collaboration tools used in the course.
- Validate tenant, subscription, role, MFA, browser, and cost-readiness before technical labs begin.
- Apply safe lab conduct rules when working in live or customer-owned environments.

Technical education content

This module establishes the operating context for a technical security workshop. Learners will use Microsoft Learn content, the Azure portal, Microsoft Defender portal, Microsoft Entra admin center, and selected lab worksheets. The course is not a click-through product tour; it is a structured exercise in translating cloud risk into prioritized security actions.

The course uses a 12-module structure. Modules 00-05 establish governance, architecture, posture, configuration, and workload selection. Modules 06-09 cover workload-specific protections. Modules 10-11 convert findings into scenario response and a 30-day roadmap.

For instructor-led one-day delivery, the four workload protection modules can be treated as selectable electives. The recommended live workshop pattern is to deliver two workload modules in depth and keep the remaining two available for self-paced reinforcement.

How the technology or topic works

The lab model separates observation from change. Observation includes viewing posture, recommendations, Secure Score, coverage, and compliance state. Change activities include enabling plans, assigning policies, deploying agents or sensors, configuring workload controls, and remediating findings. Changes must only happen in approved lab scope.

Evidence capture is part of the learning model. Learners capture screenshots, notes, risk statements, configuration decisions, and remediation tasks. The emphasis is not only on finding a risk, but on proving why the risk matters and how it will be fixed.

Each learner should work from a named identity. Shared administrator accounts weaken auditability and make it difficult to attribute changes. MFA should be active before labs begin.

Implementation guidance

1. Create a browser profile or session dedicated to the course tenant. This reduces the risk of accidental work in the wrong directory or subscription.
2. Open the Azure portal and confirm the selected Microsoft Entra directory. Record the tenant name, subscription name, subscription ID, and resource group scope that will be used for labs.

3. Open Microsoft Defender for Cloud from the Azure portal and confirm that the Overview, Recommendations, Environment settings, Workbooks, and Regulatory compliance areas are visible.
4. Open the Microsoft Defender portal and confirm whether cloud alerts and incidents are visible. Not every student needs full SOC permissions, but the instructor should confirm the operational review path.
5. Confirm cost approvals before enabling paid Defender plans. Record whether the course uses a dedicated training subscription, a shared training subscription, a demo-only environment, or a customer live subscription.

Command and query examples

Azure CLI - confirm current account and subscription

```
az account show --output table  
az account list --output table
```

Azure CLI - set subscription explicitly

```
az account set --subscription "<subscription-id-or-name>"
```

Azure CLI - list signed-in tenant details

```
az account tenant list --output table
```

Common implementation pitfalls

- Wrong tenant selected in the portal.
- Student has Reader access only but expects to enable Defender plans.
- Paid plans enabled across production subscriptions without approval.
- Lab artifacts not cleaned up after testing.
- Screenshots include confidential customer data.

Practical learning activity

Complete the student orientation checklist, confirm access, and record the selected workload modules for your delivery track.

Evidence to capture

- Completed readiness checklist
- Tenant and subscription confirmation
- Access blockers or role gaps
- Selected workload module track

Knowledge check prompts

1. Why should each student use a named account instead of a shared administrator account?
2. Which portal is used to configure Defender for Cloud environment settings?
3. Why must paid Defender plan activation be approved before class?

Module 01: Cloud Security Strategy & Governance

Attribute	Details
Classification	Core
Estimated learning time	60-90 minutes
Purpose	Align security goals to business risk and compliance requirements.
Primary output	Security goals worksheet.
Recommended evidence	Security goals worksheet; Risk register seed list; Governance scope map; Prioritized security drivers

Learning outcomes

- Translate business objectives into cloud security goals and measurable outcomes.
- Explain how risk, compliance, identity, workload criticality, and operational capability shape a cloud security strategy.
- Build a governance view that maps management groups, subscriptions, resource groups, owners, policies, and evidence requirements.
- Separate executive decisions from technical remediation actions.

Technical education content

Cloud security strategy starts with business risk. Technical controls are only meaningful when they are mapped to business outcomes such as service availability, data protection, regulatory assurance, fraud reduction, audit readiness, and incident response maturity.

Governance in Azure is normally applied through management groups, subscriptions, resource groups, resource locks, Azure Policy initiatives, role-based access control, tags, budgets, diagnostic settings, and compliance reporting. These mechanisms provide the control plane for consistent deployment and evidence generation.

A mature strategy treats identity as a security boundary. Users, groups, service principals, managed identities, workload identities, and automation accounts must be governed with least privilege and lifecycle processes. Excessive privilege creates lateral movement opportunities and increases blast radius.

Security goals should be written as measurable statements. Example: "Reduce externally exposed high-risk storage accounts by 80 percent in 30 days" is stronger than "Improve storage security" because it contains a scope, target, and timeline.

How the technology or topic works

Shared responsibility defines which security duties belong to the cloud provider and which remain with the customer. In IaaS, the customer retains more responsibility for operating systems and workloads. In PaaS and SaaS, the provider operates more of the platform, but identity, data, configuration, and governance remain critical customer responsibilities.

Zero Trust applies the principles of verify explicitly, use least privilege, and assume breach. In this course, Zero Trust appears in identity controls, network exposure decisions, Defender plan scoping, alert investigation, and remediation planning.

Governance is implemented through policy and accountability. Azure Policy evaluates resource compliance. RBAC controls who can act. Defender for Cloud recommends fixes. A remediation roadmap assigns owners, dates, dependencies, and validation criteria.

Implementation guidance

1. Define the environment boundary: which tenants, subscriptions, clouds, business units, workloads, and data classes are in scope.
2. Identify critical assets: production subscriptions, internet-facing applications, regulated data stores, identity systems, CI/CD pipelines, and AI workloads.
3. Create a simple risk register with risk statement, affected asset, business impact, likelihood, existing controls, control gaps, owner, and due date.
4. Define governance layers: management group structure, policy initiatives, allowed locations, required tags, diagnostic logging, private endpoint requirements, and public access restrictions.
5. Define escalation rules for risks that require executive sponsorship, such as production downtime risk, licensing/cost approval, legal compliance, and cross-team ownership conflicts.
6. Set measurable success indicators: secure score trend, critical recommendation count, open attack paths, privileged role count, number of unprotected workloads, and mean time to remediate.

Command and query examples

Azure CLI - list management groups

```
az account management-group list --output table
```

Azure CLI - list subscriptions

```
az account list --query "[].{Name:name, State:state, Tenant:tenantId, Subscription:id}" --output table
```

Azure CLI - list role assignments for a scope

```
az role assignment list --scope "/subscriptions/<subscription-id>" --include-inherited --output table
```

Common implementation pitfalls

- Starting with tools before defining risk appetite.
- Treating Secure Score as the only success metric.
- Ignoring identity governance while focusing only on infrastructure.
- Applying policies without exception processes.
- Assigning remediation to teams that do not own the affected resources.

Practical learning activity

Create a security goals worksheet for a sample environment or your approved lab environment. Identify the top five business-aligned security risks.

Evidence to capture

- Security goals worksheet
- Top five risk statements
- Governance scope map
- Policy and owner assumptions

Knowledge check prompts

1. What makes a security goal measurable?
2. Why is identity considered a control plane in cloud security?
3. Which risks need executive sponsorship rather than only engineering action?

Module 02: Microsoft Cloud Security Architecture

Attribute	Details
Classification	Core
Estimated learning time	60-90 minutes
Purpose	Explain Microsoft's unified security ecosystem.
Primary output	Microsoft security stack map.
Recommended evidence	Microsoft security stack map; Signal flow diagram; Service responsibility matrix

Learning outcomes

- Explain the roles of Microsoft Entra, Defender for Cloud, Defender XDR, Microsoft Sentinel, Microsoft Purview, and Azure Policy in a unified security architecture.
- Describe how posture signals, workload alerts, identity risk, data governance, and incident response are connected.
- Create a learner-level architecture map that shows which Microsoft service supports each security outcome.
- Identify integration points between prevention, detection, investigation, and response.

Technical education content

Microsoft Defender for Cloud is a cloud-native application protection platform that combines posture management and workload protection. In practical terms, it assesses cloud resources, produces recommendations, enables Defender workload plans, and forwards relevant security alerts into operational workflows.

Microsoft Entra ID provides identity and access control. It governs users, groups, application identities, workload identities, conditional access, privileged access, and directory roles. Because most cloud actions are identity-mediated, Entra design has direct security architecture impact.

Microsoft Defender XDR centralizes detection and response across Microsoft security workloads. It correlates alerts into incidents and supports investigation, advanced hunting, automated investigation, and response workflows.

Microsoft Sentinel extends security operations as a cloud-native SIEM and SOAR platform. It ingests logs from Microsoft and non-Microsoft sources, applies analytics, supports hunting using KQL, and triggers automation through playbooks.

Microsoft Purview provides data governance, data security, and compliance capabilities. In a cloud security strategy, Purview helps classify and protect sensitive data, evaluate data risk, and support evidence for regulatory obligations.

How the technology or topic works

A unified security architecture depends on signal flow. Cloud assets produce configuration state, activity logs, identity sign-in events, resource logs, Defender alerts, and compliance results. These signals are assessed by Defender for Cloud, correlated by Defender XDR or Sentinel, and converted into response actions.

Posture management answers "what is exposed or misconfigured?" Workload protection answers "what is being attacked or behaving suspiciously?" Identity security answers "who or what can access it?" Data security answers "what sensitive information is at risk?" Security operations answers "how do we detect, investigate, and respond?"

The architecture should avoid tool overlap confusion. Defender for Cloud is not a replacement for Entra governance, Purview data classification, Sentinel SIEM, or application security engineering. It is the cloud posture and workload protection anchor that integrates with those services.

Implementation guidance

1. Create a stack map with five layers: Identity, Governance, Posture, Workload Protection, and Security Operations.
2. Map Microsoft Entra to identity governance, MFA, Conditional Access, privileged access, managed identities, and workload identity security.
3. Map Azure Policy and management groups to guardrails such as allowed locations, required diagnostics, restricted public access, and required tags.
4. Map Defender for Cloud to CSPM, Defender CSPM, recommendations, regulatory compliance, environment settings, Defender plans, and coverage reporting.
5. Map Defender XDR and Sentinel to alert correlation, incident queue, advanced hunting, automation, and operational dashboards.
6. Map Purview to data classification, sensitivity labels, data loss prevention, insider risk, eDiscovery, audit, and data security posture where applicable.

Command and query examples

KQL - sample high-level incident query in Sentinel or Defender advanced hunting context

```
SecurityIncident
| summarize Incidents=count() by Severity, Status
| order by Severity asc
```

Azure CLI - list policy assignments

```
az policy assignment list --scope "/subscriptions/<subscription-id>" --query "[].{Name:name, DisplayName:displayName}" --output table
```

Common implementation pitfalls

- Assuming one Microsoft portal replaces the need for architecture design.
- Not defining log sources before building detection use cases.
- Confusing compliance dashboard results with legal compliance certification.
- Leaving workload identities out of the architecture map.
- Ignoring non-Azure or hybrid dependencies.

Practical learning activity

Build a Microsoft security stack map for the approved environment. Show which service is responsible for each control domain and evidence type.

Evidence to capture

- Stack map
- Signal flow notes
- Service responsibility matrix
- Integration assumptions

Knowledge check prompts

1. Which service provides identity and access management?
2. What is the difference between CSPM and CWPP?
3. Where should cloud alerts be investigated by the SOC?

Module 03: Cloud Security Posture Management

Attribute	Details
Classification	Core
Estimated learning time	75-120 minutes
Purpose	Introduce CSPM, secure score, recommendations, compliance, and attack paths.
Primary output	Posture review checklist.
Recommended evidence	Posture review checklist; Prioritized recommendation list; Attack path notes; Compliance gap notes

Learning outcomes

- Explain how CSPM provides continuous visibility into security state across cloud assets.
- Use Secure Score, recommendations, regulatory compliance, asset inventory, attack paths, and Cloud Security Explorer to identify risk.
- Prioritize findings using severity, exposure, exploitability, asset criticality, and business impact.
- Convert posture findings into trackable remediation tasks.

Technical education content

Cloud Security Posture Management assesses resources and workloads against security standards and policies. In Defender for Cloud, foundational CSPM is available for onboarded subscriptions, while Defender CSPM adds advanced capabilities such as attack path analysis, risk prioritization, security explorer, and AI security posture capabilities where supported.

Secure Score is a risk-oriented posture metric. It is useful for trend analysis and executive reporting, but it should not replace risk analysis. A low-impact recommendation might improve score, while an urgent exposed secret or attack path might require immediate action even if score impact is smaller.

Recommendations are generated from built-in and custom policy assessments. They can represent misconfigurations, vulnerabilities, exposed secrets, missing monitoring, weak network controls, insufficient encryption, or identity exposure.

Attack path analysis attempts to identify chained conditions that could allow an attacker to compromise a critical resource. For example, an internet-exposed VM with a critical vulnerability and a managed identity with excessive permissions creates more risk than any of those findings alone.

How the technology or topic works

The CSPM workflow begins with resource discovery. Defender for Cloud inventories assets, applies policy or benchmark checks, evaluates configuration and risk context, then produces recommendations. Learners inspect affected resources, understand remediation steps, assign ownership, and validate closure.

Regulatory compliance dashboards group controls under frameworks. They help structure evidence and audit conversations, but each organization must still interpret legal and industry obligations with appropriate compliance owners.

Governance rules can assign owners and due dates to recommendations. This turns posture management from a passive dashboard into an accountability process.

Implementation guidance

1. Open Azure portal > Microsoft Defender for Cloud > Overview. Record Secure Score, subscription coverage, critical recommendations, and any high-risk resources.
2. Open Recommendations. Filter by severity, risk level, affected resource type, owner, status, and category. Review remediation steps before taking action.
3. Group recommendations by title for a consolidated view, then drill into affected resources to identify scope and repeated patterns.
4. Open Regulatory compliance and select the relevant standard. Record control families with the largest gaps and map them back to technical recommendations.
5. If Defender CSPM is enabled, review attack paths and Cloud Security Explorer. Prioritize attack paths that involve internet exposure, privileged identity, exploitable vulnerability, sensitive data, or production resources.
6. Assign owners and dates for accepted remediation tasks. Record exceptions separately with business justification and expiry dates.

Command and query examples

Azure Resource Graph - summarize Defender for Cloud assessments

```
securityresources
| where type =~ "microsoft.security/assessments"
| extend status = tostring(properties.status.code)
| extend severity = tostring(properties.metadata.severity)
| summarize Count=count() by status, severity
| order by severity asc
```

Azure Resource Graph - list unhealthy high severity assessments

```
securityresources
| where type =~ "microsoft.security/assessments"
| extend status = tostring(properties.status.code), severity=tostring(properties.metadata.severity),
displayName=tostring(properties.displayName)
| where status =~ "Unhealthy" and severity in~ ("High", "Critical")
| project displayName, severity, resourceGroup, subscriptionId
| take 50
```

Common implementation pitfalls

- Treating every recommendation equally.
- Closing recommendations without validating remediation.
- Ignoring inherited policy assignments.
- Not distinguishing between accepted risk and remediated risk.
- Reporting only Secure Score without explaining business exposure.

Practical learning activity

Perform a posture review using Secure Score, Recommendations, Regulatory compliance, and attack path data where available. Build a prioritized findings list.

Evidence to capture

- Posture review checklist
- Top remediation candidates
- Screenshot or note of Secure Score baseline

- Attack path or risk prioritization notes

Knowledge check prompts

1. What is the difference between foundational CSPM and Defender CSPM?
2. Why can an attack path be more important than an individual recommendation?
3. How do governance rules support accountability?

Module 04: Defender for Cloud Configuration Control

Attribute	Details
Classification	Core
Estimated learning time	75-120 minutes
Purpose	Cover Defender plans, policies, onboarding, and governance controls.
Primary output	Configuration readiness checklist.
Recommended evidence	Configuration readiness checklist; Coverage workbook notes; Plan activation scope; Permissions and cost approval record

Learning outcomes

- Explain Defender for Cloud onboarding, environment settings, plan activation, connectors, permissions, and coverage validation.
- Identify which roles are required for viewing, configuring, and enabling Defender capabilities.
- Prepare a safe implementation sequence for enabling Defender plans.
- Validate coverage and identify deployment blockers.

Technical education content

Defender for Cloud is enabled per Azure subscription and can also connect hybrid and multicloud resources. When enabled, foundational capabilities include recommendations, asset inventory, workbooks, Secure Score, and regulatory compliance.

Paid Defender plans are enabled through Environment settings for selected workloads. Workload plans can deploy monitoring components, enable scanning, integrate alerts, and create additional Azure resources depending on the plan.

RBAC matters. Reader access can view posture. Contributor or Security Admin can perform many security configuration actions. Owner might be required for full plan capability enablement or when delegated permissions and dependent resource creation are involved. Least privilege remains the design goal.

Coverage validation is an engineering discipline. After enabling a plan, learners must verify that protected resources are in scope, agents or sensors are healthy where applicable, telemetry flows are active, and alerts/recommendations appear in expected portals.

How the technology or topic works

Environment settings define which subscriptions, workspaces, or connected cloud accounts are protected. Defender plans are toggled per scope, and some workloads support resource-level enablement or customization.

Azure Policy can be used to deploy or audit security controls at scale. Policy initiatives provide consistency across subscriptions and prevent manual drift.

Azure Arc extends management and security to non-Azure servers and Kubernetes clusters. AWS and GCP connectors extend posture visibility and selected protection scenarios into multicloud environments.

Implementation guidance

1. Confirm scope: subscription, management group, resource group, or resource-level enablement where supported.
2. Confirm permissions: view access, security administration access, and owner approval if full plan enablement is required.
3. Confirm cost: trial eligibility, paid plan price model, scanning caps, transaction costs, and budget alerts.

4. Open Microsoft Defender for Cloud > Environment settings. Select the subscription or environment. Review active plans and settings before making changes.
5. Enable only the required plans for the lab or approved deployment scope. Save changes and record the timestamp.
6. Open Workbooks > Coverage workbook and verify plan status across subscriptions and resources.
7. Review recommendations and alerts after a reasonable data collection period. Some signals are immediate, while others depend on resource activity, ingestion, and sensor deployment.

Command and query examples

Azure CLI - show subscription

```
az account show --output jsonc
```

Azure CLI - list Defender pricing plans

```
az security pricing list --output table
```

Azure CLI - show a Defender pricing plan

```
az security pricing show --name Storage --output jsonc
```

Azure CLI - enable Defender plan example

```
az security pricing create --name Storage --tier Standard
```

Common implementation pitfalls

- Enabling all paid plans without workload selection.
- Not checking region or feature availability.
- Missing dependent providers such as Event Grid.
- Confusing workspace-level and subscription-level settings.
- Assuming alert absence means no risk when telemetry has not yet been generated.

Practical learning activity

Complete the configuration readiness checklist and validate whether the approved environment is ready for selected Defender plan activation.

Evidence to capture

- Plan activation scope
- Permissions record
- Cost approval note
- Coverage workbook findings
- Configuration blockers

Knowledge check prompts

1. Where are Defender plans enabled?
2. What is the purpose of the coverage workbook?
3. Why should plan activation be scoped and documented?

Module 05: Workload Protection Decision Matrix

Attribute	Details
Classification	Core
Estimated learning time	45-75 minutes
Purpose	Help learners select priority workload protection areas.
Primary output	Workload protection matrix.
Recommended evidence	Workload protection decision matrix; Selected workload rationale; Implementation readiness ranking

Learning outcomes

- Compare workload protection options across Storage, Containers, App Service, and AI Services.
- Select workload modules using business impact, threat exposure, data sensitivity, implementation effort, and cost exposure.
- Explain why different organizations should prioritize different workload protections.
- Create a defensible workload selection recommendation.

Technical education content

Cloud workload protection should be risk-led. Storage is often prioritized when untrusted uploads, sensitive data, data lake ingestion, or partner file exchange are in scope. Containers are prioritized when AKS, registries, microservices, and CI/CD image pipelines are business-critical. App Service is prioritized for internet-facing web workloads. AI Services are prioritized where generative AI, model endpoints, prompt handling, or AI agents process business data.

The decision matrix balances exposure, impact, readiness, dependency, cost, and evidence. A workload can be high risk but not immediately ready for live implementation if permissions, licensing, supported regions, or representative test resources are missing.

A good decision matrix avoids tool bias. The correct workload module is not always the newest feature. It is the one that reduces the largest practical risk within the available scope and time.

How the technology or topic works

Score each workload from 1 to 5 across selected criteria. Multiply by weights if the customer has strong priorities. For example, regulated data might make data sensitivity a higher weight than implementation effort.

Separate learning priority from deployment priority. A team may choose AI Services for learning because AI risk is emerging, while choosing Storage for immediate deployment because untrusted uploads are already in production.

Document assumptions. If AKS is not present in the environment, Defender for Containers can still be studied, but live implementation should move to demo or self-paced mode.

Implementation guidance

1. List all workload candidates in the environment: storage accounts, AKS clusters, container registries, App Service apps, Azure AI resources, and Microsoft Foundry projects.
2. Score each candidate against data sensitivity, internet exposure, likelihood of attack, business impact, current control maturity, implementation readiness, and cost concern.
3. Select two workload modules for deep dive. Include one primary module with immediate implementation value and one strategic module that improves future readiness.
4. Record reasons for deprioritized modules so that they can be included in the 30-day roadmap instead of being lost.

5. Use the matrix result to define lab scope, required permissions, and evidence capture for Modules 06-09.

Command and query examples

Azure CLI - list storage accounts

```
az storage account list --query "[].{Name:name, ResourceGroup:resourceGroup, Location:location}" --output table
```

Azure CLI - list AKS clusters

```
az aks list --query "[].{Name:name, ResourceGroup:resourceGroup, KubernetesVersion:kubernetesVersion}" --output table
```

Azure CLI - list App Service web apps

```
az webapp list --query "[].{Name:name, ResourceGroup:resourceGroup, State:state, Host:defaultHostName}" --output table
```

Azure CLI - list Cognitive Services accounts

```
az cognitiveservices account list --query "[].{Name:name, Kind:kind, ResourceGroup:resourceGroup, Location:location}" --output table
```

Common implementation pitfalls

- Selecting modules based only on learner preference.
- Ignoring cost and permissions readiness.
- Choosing a workload without representative lab resources.
- Failing to document why some workloads were deferred.
- Not aligning selected modules with the capstone roadmap.

Practical learning activity

Complete the workload protection matrix and select two workload modules for practical deep dive or lab demonstration.

Evidence to capture

- Completed scoring matrix
- Selected workload rationale
- Deferred workload notes
- Implementation blockers

Knowledge check prompts

1. Which criteria should influence workload selection?
2. Why might a high-risk workload be deferred from live implementation?
3. How do you distinguish learning priority from deployment priority?

Module 06: Defender for Storage

Attribute	Details
Classification	Workload Protection
Estimated learning time	75-120 minutes
Purpose	Explore storage protection, malware upload risks, and suspicious access.
Primary output	Storage protection scenario review.
Recommended evidence	Storage protection scenario review; Storage control checklist; Malware scanning configuration notes; Remediation plan

Learning outcomes

- Explain the security risks associated with Azure Storage accounts and untrusted content.
- Describe how Defender for Storage detects suspicious access, malicious content, and sensitive data risks.
- Configure or plan Defender for Storage at subscription or resource level.
- Design a response pattern for malware scanning and suspicious access findings.

Technical education content

Azure Storage exposes both control plane and data plane risk. Control plane actions create, configure, or delete accounts and containers. Data plane actions read, write, list, copy, and delete blobs and files. Attackers may target account keys, SAS tokens, public containers, misconfigured network access, compromised identities, and application upload paths.

Defender for Storage provides an Azure-native security layer for storage accounts. It analyzes data and control plane activity, applies Microsoft threat intelligence, and detects anomalous behavior such as suspicious access, unexpected access patterns, and malicious uploads.

Malware scanning can scan blobs and files using Microsoft Defender Antivirus. On-upload scanning evaluates new or modified blobs. On-demand scanning can scan existing content for baseline, incident response, or compliance use cases. Malware scanning is agentless and can return results through alerts, blob index tags, Event Grid, or Log Analytics depending on configuration.

Hash reputation analysis compares uploaded blob or file hashes against known malware intelligence. It is different from full malware scanning because it is based on known hash signals rather than content scanning of the full object.

How the technology or topic works

On-upload scanning depends on upload or modification events. When malware scanning is enabled, Azure uses supporting resources and managed identity mechanisms to read and scan blobs. Event Grid integration supports near-real-time response patterns.

Cost control is important. Malware scanning can be billed per gigabyte scanned and may incur dependent Azure service charges such as storage read operations, blob index tags, and Event Grid events. Monthly scanning caps and path filters help limit exposure.

A secure storage design should combine Defender for Storage with least privilege, private endpoints, network restrictions, disabled anonymous public access, key rotation, SAS governance, soft delete, versioning, immutable storage where appropriate, and diagnostic logging.

Implementation guidance

1. Open Microsoft Defender for Cloud > Environment settings. Select the subscription and enable the Storage plan only if approved.
2. For subscription-level enablement, confirm that all current and future storage accounts should be protected. If not, use resource-level enablement or exclusion patterns where supported.
3. For resource-level enablement, open the storage account > Security + networking > Microsoft Defender for Cloud, then enable Defender for Storage on the storage account.
4. Review settings for on-upload malware scanning, sensitive data threat detection, monthly scanning cap, scan filters, blob index tag storage, Event Grid notification, Log Analytics result export, and malicious blob soft deletion.
5. Register or validate dependent providers such as Microsoft.EventGrid where malware scanning requires event triggers.
6. Design response automation. Example: when Event Grid receives a malicious scan result, move the blob to quarantine, remove access, create a ticket, and notify the security team.
7. Validate protection by reviewing Defender alerts, scan result tags, Log Analytics records, and storage configuration posture. Use safe test files and approved lab-only containers.

Command and query examples

Azure CLI - list storage accounts and public network access

```
az storage account list --query "[].{Name:name, ResourceGroup:resourceGroup, PublicNetworkAccess:publicNetworkAccess, AllowBlobPublicAccess:allowBlobPublicAccess}" --output table
```

Azure CLI - disable blob public access on a storage account

```
az storage account update --name <storage-account> --resource-group <rg> --allow-blob-public-access false
```

Azure CLI - enable Defender for Storage plan

```
az security pricing create --name Storage --tier Standard
```

KQL - storage read/write operations if diagnostic logs are enabled

```
StorageBlobLogs
| summarize Operations=count() by OperationName, AuthenticationType, StatusCode
| order by Operations desc
```

Common implementation pitfalls

- Uploading real customer data during testing.
- Assuming malware scanning replaces access control.
- Not setting scan caps for high-volume ingestion workloads.
- Failing to plan false-positive handling.
- Leaving public network access unrestricted without justification.

Practical learning activity

Review a storage security scenario involving untrusted uploads and suspicious access. Recommend configuration, detection, response, and remediation controls.

Evidence to capture

- Storage protection scenario review
- Storage account settings summary

- Malware scanning configuration notes
- Response automation design
- Remediation tasks

Knowledge check prompts

1. What is the difference between on-upload and on-demand malware scanning?
2. Why are SAS tokens a storage security risk?
3. Which controls reduce the risk of malware distribution through storage?

Module 07: Defender for Containers

Attribute	Details
Classification	Workload Protection
Estimated learning time	75-120 minutes
Purpose	Explore AKS, Kubernetes, image risk, and runtime protection.
Primary output	Container security scenario review.
Recommended evidence	Container security scenario review; AKS readiness notes; Image and runtime risk checklist; Remediation plan

Learning outcomes

- Explain security risks across container images, registries, Kubernetes clusters, nodes, workloads, and runtime behavior.
- Describe how Defender for Containers supports posture management, vulnerability visibility, and runtime threat detection.
- Identify implementation prerequisites for AKS and container registry protection.
- Recommend hardening actions for Kubernetes and containerized workloads.

Technical education content

Container security spans the software supply chain and runtime environment. Risk can enter through vulnerable base images, exposed secrets, weak Dockerfiles, insecure Kubernetes manifests, overly permissive RBAC, privileged containers, hostPath mounts, exposed dashboards, public registries, and unpatched node images.

AKS separates the managed control plane from customer-managed node pools and workloads. The customer remains responsible for workload security, namespace isolation, Kubernetes RBAC, network policies, image provenance, secret handling, ingress configuration, and runtime detection.

Defender for Containers protects containerized assets such as clusters, nodes, workloads, registries, and images. Capabilities can include posture recommendations, vulnerability assessment, runtime threat alerts, sensor deployment, and multicloud or on-premises coverage depending on environment support.

Runtime protection focuses on suspicious behavior after deployment. Examples include crypto-mining, suspicious process execution, container escape indicators, credential access, malicious network behavior, or Kubernetes API abuse.

How the technology or topic works

The container protection lifecycle starts before deployment. Build pipelines should scan images and IaC. Registries should restrict who can push or pull. Clusters should enforce admission standards. Runtime sensors and platform logs should detect suspicious behavior.

A secure AKS baseline typically includes managed identities, Azure AD integration, Kubernetes RBAC, network policy, private clusters where appropriate, restricted egress, secrets in Key Vault, workload identity, image signing or provenance, and regular node image upgrades.

Defender signals are most valuable when mapped to ownership. Platform teams own cluster configuration. Development teams own image remediation. Security operations own alert triage and response. Governance teams own policy and exception processes.

Implementation guidance

1. Confirm that an AKS cluster, container registry, and sample workload exist in the lab scope. Avoid production clusters for learner experimentation unless explicitly approved.
2. Open Microsoft Defender for Cloud > Environment settings and enable Defender for Containers for the approved subscription or connected environment.
3. Verify that required components and sensors are deployed and healthy. Some environments require agent or extension deployment and network connectivity to Microsoft endpoints.
4. Review Defender for Cloud recommendations for AKS, container registries, and Kubernetes workloads. Prioritize privileged containers, unrestricted capabilities, exposed services, outdated images, and missing network controls.
5. Inspect container images for vulnerability findings. Assign image remediation to the owning development or platform team with base image, package, and rebuild requirements.
6. Validate Kubernetes hardening: namespace boundaries, RBAC, pod security standards, image pull policy, secret mounting, ingress exposure, network policies, and workload identity.
7. Review alerts in Defender portal or Defender for Cloud. Map suspicious behavior to MITRE tactics and determine containment actions.

Command and query examples

kubectl - identify cluster and nodes

```
kubectl cluster-info
kubectl get nodes -o wide
```

kubectl - list high-level workloads

```
kubectl get pods,svc,deploy,ingress --all-namespaces
```

kubectl - find privileged containers

```
kubectl get pods --all-namespaces -o jsonpath="{range .items[*]}{.metadata.namespace}/{.metadata.name}{ \" privileged=\"}
{.spec.containers[*].securityContext.privileged}{ \"\\n\"}{end}"
```

Azure CLI - list AKS clusters

```
az aks list --query "[].{Name:name, ResourceGroup:resourceGroup, KubernetesVersion:kubernetesVersion, Location:location}" --
output table
```

Common implementation pitfalls

- Scanning images but not fixing base image ownership.
- Treating Kubernetes RBAC and Azure RBAC as the same thing.
- Ignoring runtime behavior after a clean image scan.
- Deploying sensors without checking network requirements.
- Leaving test workloads running after labs.

Practical learning activity

Review a container security scenario involving vulnerable images, permissive pod settings, and exposed services. Recommend posture and runtime protection actions.

Evidence to capture

- Container security scenario review
- AKS readiness notes

- Image vulnerability notes
- Runtime control plan
- Remediation owners

Knowledge check prompts

1. Why does container security begin before runtime?
2. What risks are introduced by privileged containers?
3. How should image vulnerability remediation be assigned?

Module 08: Defender for App Service

Attribute	Details
Classification	Workload Protection
Estimated learning time	75-120 minutes
Purpose	Explore web app and cloud-native application protection.
Primary output	App Service protection scenario review.
Recommended evidence	App Service protection scenario review; Web workload hardening checklist; Runtime alert interpretation notes; Remediation plan

Learning outcomes

- Explain common security risks for Azure App Service and cloud-native web applications.
- Describe how Defender for App Service assesses and detects threats against web workloads.
- Identify configuration, identity, network, and runtime controls for App Service.
- Recommend mitigations for scanning, execution, exposed secrets, and dangling DNS scenarios.

Technical education content

Azure App Service abstracts server management but does not remove application security responsibility. Developers and operators still manage authentication, authorization, input validation, secrets, deployment pipelines, custom domains, TLS settings, network access, managed identity, dependencies, and logging.

Defender for App Service provides secure recommendations and threat detection for App Service resources. It can detect pre-attack reconnaissance such as vulnerability scanners, suspicious access from known malicious IPs, suspicious execution behavior, mining activity, and dangling DNS risks related to decommissioned web apps.

Dangling DNS occurs when a custom domain record remains in DNS after the original App Service target is removed or no longer owns the hostname. Attackers may claim the orphaned target and receive traffic intended for the organization.

App Service should normally be protected with layered controls: HTTPS only, current TLS, FTPS-only or FTP disabled, managed identity, Key Vault references, private endpoints where needed, access restrictions, WAF in front of public apps, diagnostic logging, and secure deployment practices.

How the technology or topic works

Defender for App Service evaluates covered resources and produces recommendations. It also uses cloud-scale telemetry and threat intelligence to detect attacker behaviors that may be difficult to recognize from one app instance alone.

Application security differs from infrastructure security. Defender can detect and recommend controls, but secure coding, dependency management, authentication design, authorization checks, API validation, and secrets management remain engineering responsibilities.

Operational response should connect App Service alerts to logs, deployment history, code changes, identity changes, and network exposure. A runtime alert without application context is difficult to triage.

Implementation guidance

1. Open Microsoft Defender for Cloud > Environment settings and enable Defender for App Service for the approved subscription if in scope.

2. Identify the target web app and record App Service Plan, runtime stack, hostname, custom domains, deployment slots, managed identity state, and network exposure.
3. Review App Service recommendations in Defender for Cloud. Prioritize public exposure, TLS, authentication, managed identity, secrets, logging, and deployment controls.
4. Harden the app: enforce HTTPS, set minimum TLS, disable plain FTP, use FTPS-only if file transfer is required, configure managed identity, move secrets to Key Vault, restrict SCM/Kudu where possible, and enable diagnostics.
5. For internet-facing apps, place Azure Front Door, Application Gateway WAF, or another approved edge control in front of the service where the architecture requires inspection and DDoS-resistant exposure.
6. Review DNS lifecycle. When decommissioning apps or slots, remove custom DNS records and validate that no CNAME or A record points to a deleted or unclaimed endpoint.
7. Review alerts for scanning, malicious IP access, suspicious process execution, or DNS risk. Correlate with AppServiceHTTPLogs, AppServiceConsoleLogs, deployment logs, and identity events where available.

Command and query examples

Azure CLI - list web apps

```
az webapp list --query "[].{Name:name, ResourceGroup:resourceGroup, Host:defaultHostName, State:state}" --output table
```

Azure CLI - enforce HTTPS only

```
az webapp update --name <app-name> --resource-group <rg> --https-only true
```

Azure CLI - set FTPS only

```
az webapp config set --name <app-name> --resource-group <rg> --ftps-state FtpsOnly
```

Azure CLI - assign system managed identity

```
az webapp identity assign --name <app-name> --resource-group <rg>
```

Common implementation pitfalls

- Storing secrets in application settings without Key Vault governance.
- Leaving FTP enabled unnecessarily.
- Removing an app but leaving custom DNS records in place.
- Assuming PaaS removes the need for application threat modeling.
- Not enabling logs before an incident occurs.

Practical learning activity

Review an App Service scenario involving internet exposure, weak settings, and suspicious web activity. Recommend secure configuration and incident response actions.

Evidence to capture

- App Service protection scenario review
- App settings summary
- DNS and custom domain review notes
- Runtime alert notes
- Remediation plan

Knowledge check prompts

1. What is dangling DNS and why is it dangerous?

2. Which App Service settings reduce transport and deployment risk?
3. Why does Defender for App Service not replace secure coding?

Module 09: Defender for AI Services

Attribute	Details
Classification	Workload Protection
Estimated learning time	90-150 minutes
Purpose	Explore GenAI security, prompt injection, data leakage, and AI monitoring.
Primary output	AI security risk review.
Recommended evidence	AI security risk review; Prompt and data handling rules; AI identity control notes; Defender AI monitoring plan

Learning outcomes

- Explain GenAI-specific security risks such as prompt injection, indirect prompt injection, jailbreaks, data leakage, unsafe tool invocation, and data poisoning.
- Describe how Microsoft Defender for Cloud AI threat protection and Azure AI Content Safety Prompt Shields contribute to AI workload protection.
- Design identity, network, data, monitoring, and guardrail controls for AI services and Microsoft Foundry workloads.
- Produce an AI security risk review suitable for inclusion in a 30-day remediation roadmap.

Technical education content

AI workloads introduce both traditional cloud risks and AI-specific risks. Traditional risks include exposed endpoints, weak keys, over-permissive RBAC, missing private networking, poor logging, and insecure data stores. AI-specific risks include prompt injection, indirect prompt injection through documents or external content, jailbreak attempts, data leakage, unsafe output, tool misuse, model abuse, and poisoned data sources.

Direct prompt injection occurs when a user intentionally tries to override instructions or safety rules. Indirect prompt injection occurs when the model consumes untrusted content such as documents, emails, web pages, or tickets that contain malicious instructions. Agentic systems increase impact because the model may call tools, access data, or perform actions.

Defender for Cloud AI threat protection detects and helps respond to threats targeting generative AI applications and agents. It integrates with Defender XDR to centralize alerts and correlate AI workload activity with broader incidents.

Azure AI Content Safety Prompt Shields can analyze prompts and documents for attempts to manipulate model behavior. Guardrails should be combined with identity boundaries, data classification, network controls, logging, human approval for high-impact actions, and least-privilege tool access.

How the technology or topic works

AI security works as a layered control system. Input controls inspect user prompts and retrieved content. Identity controls limit which users, apps, agents, and managed identities can invoke models or tools. Data controls prevent sensitive or unauthorized data from entering prompts. Output controls filter unsafe responses. Monitoring controls detect abnormal usage and attacks.

Prompt protection is not the same as data governance. A prompt shield can help identify manipulative input, but sensitive data still needs classification, access control, retention rules, and data loss prevention policies.

AI workloads should use managed identities where possible, private endpoints for sensitive services, network isolation, key rotation, Key Vault, RBAC, logging, and explicit approval for tool actions that affect production systems.

Implementation guidance

1. Inventory AI resources: Azure OpenAI, Azure AI services, Microsoft Foundry projects, model deployments, connected data sources, storage accounts, search indexes, app services, containers, and agents.
2. Open Defender for Cloud and confirm whether AI workload posture or AI threat protection features are available and enabled in the approved subscription and region.
3. Enable the relevant Defender plan for AI services only after confirming permissions, cost, and supported resource types. Owner or Contributor may be required depending on plan and scope.
4. Configure Azure AI Content Safety Prompt Shields for user prompts and document inputs where the AI workload consumes untrusted content.
5. Implement data handling rules: no secrets, personal data, customer confidential data, regulated records, or production credentials in lab prompts. Use synthetic or approved sample data.
6. Harden identity: use managed identities, remove shared keys where possible, avoid broad Contributor permissions, scope agent tool permissions, require Conditional Access for administrators, and review role assignments.
7. Harden network and data paths: use private endpoints for sensitive resources, restrict public network access where feasible, log requests, protect retrieval sources, and separate training, test, and production data.
8. Review Defender XDR or Defender for Cloud alerts for AI activity. Correlate prompt attack, data leakage, credential theft, and suspicious resource access with identity, network, and application telemetry.

Command and query examples

Azure CLI - list AI/Cognitive Services accounts

```
az cognitiveservices account list --query "[].{Name:name, Kind:kind, ResourceGroup:resourceGroup, Location:location}" --output table
```

Azure CLI - list role assignments on an AI resource

```
az role assignment list --scope "<resource-id>" --include-inherited --output table
```

Azure CLI - list private endpoint connections for a resource

```
az network private-endpoint-connection list --id "<resource-id>" --output table
```

Common implementation pitfalls

- Testing prompt attacks with real confidential data.
- Assuming prompt filtering alone secures an AI system.
- Giving agents broad permissions to production resources.
- Ignoring indirect prompt injection through retrieved documents.
- Failing to log AI application actions and tool invocations.

Practical learning activity

Analyze an AI workload scenario involving GenAI prompt input, connected data sources, and tool access. Identify posture, identity, data, guardrail, and monitoring controls.

Evidence to capture

- AI security risk review
- AI resource inventory notes
- Prompt and data handling rules
- Identity control recommendations
- Monitoring and alerting plan

Knowledge check prompts

1. What is the difference between direct and indirect prompt injection?
2. Why should AI agents use least-privilege tool access?
3. How do Prompt Shields and Defender AI threat protection complement each other?

Module 10: Hands-On Security Scenarios

Attribute	Details
Classification	Applied Practice
Estimated learning time	90-150 minutes
Purpose	Apply course concepts to realistic security incidents.
Primary output	Remediation planning worksheet.
Recommended evidence	Remediation planning worksheet; Scenario timeline; Root cause analysis; Control mapping

Learning outcomes

- Apply course concepts to realistic cloud security incidents and exposure scenarios.
- Perform triage, scope, impact analysis, root cause analysis, and remediation planning.
- Map findings to Microsoft security controls and operational owners.
- Produce a remediation worksheet that is actionable and evidence-based.

Technical education content

Scenario work turns posture management into operational decision-making. A finding such as "public network access enabled" becomes meaningful only when connected to asset criticality, data sensitivity, attacker path, operational impact, and remediation feasibility.

A good investigation separates symptom, root cause, contributing factors, and corrective action. For example, malware in storage is a symptom. Untrusted upload without scanning is a control gap. Lack of an ingestion security standard is a governance root cause.

Remediation planning should include containment, eradication, recovery, validation, and prevention. Some findings can be fixed by configuration. Others require application changes, identity redesign, policy enforcement, or budget approval.

Scenario analysis should map to MITRE tactics where useful, but the goal is practical remediation rather than academic classification.

How the technology or topic works

Triage starts with what happened, what is affected, how severe it is, and whether active compromise is suspected. Scope then identifies all related resources, identities, network paths, secrets, and data stores.

Root cause analysis asks why the condition existed. Common root causes include missing policy, inherited permissions, default settings, lack of logging, unsupported service region, orphaned DNS, poor ownership, weak CI/CD controls, or ungoverned AI experimentation.

Control mapping identifies where the fix belongs: identity, network, data, application, platform, monitoring, governance, or operations.

Implementation guidance

1. Select one scenario: suspicious storage upload, over-privileged identity, attack path to critical resource, exposed App Service, vulnerable AKS workload, or AI prompt injection attempt.
2. Record initial facts: alert or recommendation name, affected resource, severity, owner, environment, first seen time, and available evidence.

3. Scope related assets using resource group, tags, managed identities, private endpoints, diagnostic logs, deployment history, and role assignments.
4. Determine likely root cause and contributing factors. Use "Five Whys" but keep the answer evidence-based.
5. Define immediate actions: contain exposure, disable risky key or token, restrict network access, quarantine malicious content, stop vulnerable workload, or assign emergency owner.
6. Define durable fixes: policy initiative, CI/CD check, RBAC cleanup, Defender plan enablement, monitoring rule, architecture change, runbook, or training action.
7. Validate remediation with a before/after check. Confirm recommendation state, secure score movement, alert closure, log evidence, or configuration change.

Command and query examples

Azure CLI - show resource by ID

```
az resource show --ids "<resource-id>" --output jsonc
```

Azure CLI - list role assignments on a resource

```
az role assignment list --scope "<resource-id>" --include-inherited --output table
```

KQL - high-level alert summary example

```
SecurityAlert
| summarize Alerts=count() by AlertSeverity, ProductName
| order by Alerts desc
```

Common implementation pitfalls

- Jumping to remediation before confirming scope.
- Closing alerts without documenting validation.
- Ignoring ownership and change control.
- Treating every scenario as purely technical.
- Not capturing enough evidence for audit or learning review.

Practical learning activity

Work through selected hands-on security scenarios and complete a remediation planning worksheet for each assigned scenario.

Evidence to capture

- Scenario timeline
- Root cause statement
- Affected asset list
- Control mapping
- Remediation planning worksheet

Knowledge check prompts

1. What is the difference between containment and durable remediation?
2. Why is scope analysis required before making changes?
3. How do you validate that a remediation reduced risk?

Module 11: Capstone Roadmap

Attribute	Details
Classification	Capstone
Estimated learning time	60-120 minutes
Purpose	Build a practical 30-day security improvement plan.
Primary output	Final remediation roadmap.
Recommended evidence	Final 30-day remediation roadmap; Executive summary; Owner and dependency register; Success metrics

Learning outcomes

- Build a practical 30-day security improvement roadmap from course findings.
- Prioritize actions by risk reduction, implementation effort, dependency, owner readiness, and cost.
- Define measurable success criteria for posture, workload protection, identity, data, and operations.
- Present a roadmap that can guide post-course execution.

Technical education content

The capstone roadmap is the bridge between training and implementation. It should translate posture findings, workload decisions, scenario lessons, and governance gaps into a sequence of executable actions.

A 30-day roadmap should not attempt to solve every security problem. It should focus on high-risk exposures, foundational governance, quick wins, and enabling work that unlocks later improvements.

Prioritization should consider risk reduction, blast-radius reduction, effort, owner availability, change windows, licensing, tooling readiness, and dependencies. A task with high security value but no owner is not executable until ownership is fixed.

Success metrics should include both activity metrics and outcome metrics. Activity metrics include number of plans enabled or recommendations assigned. Outcome metrics include reduction in critical recommendations, closed attack paths, reduced public exposure, and validated coverage.

How the technology or topic works

The roadmap should be organized by time horizon. Days 0-3 stabilize scope, ownership, and critical exposures. Days 4-10 address quick wins and high-risk misconfigurations. Days 11-20 implement workload protection and governance rules. Days 21-30 validate, report, and prepare the next maturity cycle.

Each action should include owner, due date, dependency, risk addressed, implementation notes, validation method, and evidence location.

Capstone presentation should be understandable to executives and useful to engineers. Avoid burying business risk inside tool-specific terminology.

Implementation guidance

1. Consolidate outputs from Modules 01-10: risk goals, stack map, posture findings, configuration readiness, workload matrix, workload-specific reviews, and scenario remediation worksheets.
2. Group actions into themes: Identity and Access, Posture and Governance, Workload Protection, Data and AI Security, Security Operations, and Reporting.
3. Use a prioritization model: Critical path first, quick wins second, governance enablers third, strategic improvements fourth. Record deferred items with reason and target date.

4. Create a 30-day action table with action, owner, priority, start date, target date, effort, dependencies, risk addressed, and validation evidence.
5. Create a concise executive summary: current state, top risks, selected workload priorities, first 30-day actions, expected risk reduction, and decisions required.
6. Define operational cadence: daily stand-up during first week, weekly remediation review, exception review, and final validation report.

Command and query examples

Roadmap action format

Action: Restrict public access on high-risk storage accounts
 Owner: Cloud Platform Team
 Due: Day 7
 Validation: Defender recommendation resolved and storage network settings reviewed

Executive risk statement format

Risk: Untrusted uploads can introduce malware into shared storage.
 Impact: Downstream systems may distribute infected content.
 Action: Enable Defender for Storage malware scanning and quarantine automation.

Common implementation pitfalls

- Creating a roadmap with no owners.
- Selecting too many actions for 30 days.
- Omitting validation evidence.
- Ignoring cost and change windows.
- Failing to escalate decisions that require leadership approval.

Practical learning activity

Build and present a 30-day remediation roadmap based on the course evidence and selected workload priorities.

Evidence to capture

- Final remediation roadmap
- Executive summary
- Owner and dependency register
- Success metrics
- Deferred risk list

Knowledge check prompts

1. What belongs in the first seven days of a remediation roadmap?
2. How should success be measured?
3. Why must deferred risks be documented?

6. Worksheets and Templates

6.1 Security Goals Worksheet

Business driver	Security objective	Risk reduced	Metric	Owner

6.2 Posture Review Checklist

Area	Question	Status	Evidence / notes
Secure Score	Has the current score and trend been recorded?		
Recommendations	Have critical and high recommendations been reviewed?		
Attack paths	Have attack paths been reviewed where available?		
Regulatory compliance	Which standards or controls have the largest gaps?		
Ownership	Are recommendation owners and due dates assigned?		
Validation	How will remediation closure be verified?		

6.3 Workload Protection Decision Matrix

Workload	Data sensitivity	Internet exposure	Business impact	Readiness	Cost concern	Priority
Storage						
Containers						
App Service						
AI Services						

6.4 Remediation Planning Worksheet

Finding	Risk	Root cause	Action	Owner	Due date	Validation

6.5 30-Day Roadmap Template

Timeframe	Action	Owner	Dependency	Risk addressed	Success measure
Days 0-3					

Timeframe	Action	Owner	Dependency	Risk addressed	Success measure
Days 4-10					
Days 11-20					
Days 21-30					

7. Glossary

Term	Definition
AI prompt injection	An attack that attempts to manipulate an AI system by embedding instructions that override intended behavior.
Attack path	A chain of conditions that could allow an attacker to move from an initial weakness to a critical asset.
Azure Policy	A governance service used to create, assign, and manage policy definitions that enforce or audit resource compliance.
CNAPP	Cloud-Native Application Protection Platform. A platform category that combines posture management, workload protection, DevSecOps, and cloud risk visibility.
CSPM	Cloud Security Posture Management. Continuous assessment of cloud resources against security standards and recommended configurations.
CWPP	Cloud Workload Protection Platform. Protection for running workloads such as VMs, containers, storage, databases, serverless, and AI services.
Defender XDR	Microsoft extended detection and response capabilities for correlating alerts, incidents, and investigations across Microsoft security products.
Managed identity	An Azure identity assigned to a resource so it can authenticate to other services without storing credentials in code.
Microsoft Entra ID	Microsoft cloud identity and access management service used to control access to applications, resources, and data.
Prompt Shields	Azure AI Content Safety capability designed to detect prompt attacks in user prompts and documents.
RBAC	Role-Based Access Control. A model for granting permissions based on role assignments at a defined scope.
Secure Score	A posture metric used to assess and monitor cloud security posture and risk mitigation progress.
SIEM	Security Information and Event Management. Centralized security data collection, analytics, detection, and reporting.
SOAR	Security Orchestration, Automation, and Response. Automated response and workflow orchestration for security operations.
Zero Trust	A security model based on verify explicitly, use least privilege, and assume breach.

8. Reference and Source Alignment

The content in this manual aligns to the course syllabus, pre-course readiness requirements, Microsoft Learn collection materials, and the following Microsoft documentation. Learners should validate portal labels, licensing, regional availability, and preview/GA status against the live documentation before production use.

ID	Reference	URL
MS-DFC-OVERVIEW	Microsoft Defender for Cloud overview	https://learn.microsoft.com/en-us/azure/defender-for-cloud/defender-for-cloud-introduction
MS-DFC-CONNECT	Connect Azure subscriptions to Defender for Cloud	https://learn.microsoft.com/en-us/azure/defender-for-cloud/connect-azure-subscription
MS-DFC-PERMISSIONS	Defender for Cloud user roles and permissions	https://learn.microsoft.com/en-us/azure/defender-for-cloud/permissions
MS-CSPM	Cloud Security Posture Management in Defender for Cloud	https://learn.microsoft.com/en-us/azure/defender-for-cloud/concept-cloud-security-posture-management
MS-RECOMMENDATIONS	Review security recommendations in Defender for Cloud	https://learn.microsoft.com/en-us/azure/defender-for-cloud/review-security-recommendations
MS-STORAGE	What is Microsoft Defender for Storage	https://learn.microsoft.com/en-us/azure/defender-for-cloud/defender-for-storage-introduction
MS-STORAGE-ENABLE	Enable and configure Defender for Storage	https://learn.microsoft.com/en-us/azure/defender-for-cloud/defender-for-storage-azure-portal-enablement
MS-STORAGE-MALWARE	Malware scanning in Defender for Storage	https://learn.microsoft.com/en-us/azure/defender-for-cloud/introduction-malware-scanning
MS-CONTAINERS	Microsoft Defender for Containers introduction	https://learn.microsoft.com/en-us/azure/defender-for-cloud/defender-for-containers-introduction
MS-APP-SERVICE	Microsoft Defender for App Service benefits and features	https://learn.microsoft.com/en-us/azure/defender-for-cloud/defender-for-app-service-introduction
MS-AI-THREAT	AI threat protection in Microsoft Defender for Cloud	https://learn.microsoft.com/en-us/azure/defender-for-cloud/ai-threat-protection
MS-PROMPT-SHIELDS	Prompt Shields in Azure AI Content Safety	https://learn.microsoft.com/en-us/azure/ai-services/content-safety/concepts/jailbreak-detection
MS-SENTINEL	What is Microsoft Sentinel SIEM	https://learn.microsoft.com/en-us/azure/sentinel/overview
MS-PURVIEW	Microsoft Purview overview	https://learn.microsoft.com/en-us/purview/purview
MS-ENTRA	Microsoft Entra ID documentation	https://learn.microsoft.com/en-us/entra/identity/

9. Course Completion Checklist

- I can explain the CESE323 module structure and final capstone expectations.
- I can describe how business risk maps to security goals and governance controls.
- I can map Microsoft Entra, Defender for Cloud, Defender XDR, Sentinel, and Purview to security outcomes.
- I can use CSPM concepts to review Secure Score, recommendations, regulatory compliance, and attack paths.
- I can explain how Defender plans are enabled, scoped, validated, and governed.
- I can select workload protection priorities using a documented decision matrix.
- I can explain the key protections for Storage, Containers, App Service, and AI Services.
- I can complete a scenario-based remediation worksheet with root cause, owner, due date, and validation evidence.
- I can build a practical 30-day remediation roadmap from course findings.